

Manual 20 — Implementación Controlada de CIS Controls v8.1

Localización controlada es-419 — candidata asistida por máquina

****Orden de serie:**** 20

****Fuente inglesa congelada:**** blob `d257e418e8839fe8694ca943760c65e43c7e1644`

****Límite:**** Guía de implementación derivada de conceptos actuales de CIS Controls v8.1 sin reproducir texto protegido de CIS. Mantener separados CIS Controls, Safeguards, Implementation Groups, CIS Benchmarks, mapeos de marcos y procedimientos específicos de la organización. No implicar certificación ni respaldo de CIS. Esta localización de proyecto es no oficial. Solo existe una revisión humana sustantiva como bloqueo cuando una cuestión específica, documentada y no determinista requiere juicio humano; de lo contrario aplica la regla canónica de publicación para candidatos sin errores ni asuntos materiales pendientes.

1. Propósito, alcance y límites de fuentes

Definir el alcance organizacional, objetivos de seguridad, referencias autoritativas de CIS, restricciones de licencia/copyright y uso previsto. Evidencia: declaración de alcance, registro de fuentes y aprobación de gobernanza.

2. Gobernanza y aplicabilidad

Establecer propiedad ejecutiva, gobierno de seguridad, jerarquía de políticas, responsabilidad y criterios de aplicabilidad. Evidencia: estatuto, RACI, registro de políticas y decisiones.

3. Selección del Implementation Group

Seleccionar y justificar la postura de Implementation Group aplicable considerando riesgo organizacional, recursos, exposición a amenazas, datos, misión y complejidad operativa. Evidencia: memorando de decisión de IG y disparadores de reevaluación.

4. Inventario de activos empresariales

Mantener inventarios autoritativos de activos, propietarios, identidad de red, criticidad, estado de ciclo de vida y condición aprobada. Conciliar resultados de descubrimiento e investigar activos no administrados.

5. Inventario y ciclo de vida de software

Mantener inventarios de software autorizado, versiones, propietario, soporte, propósito de negocio y procesos de retiro. Evidencia: registro de software, conciliación con descubrimiento y remediación de software sin soporte.

6. Protección y clasificación de datos

Inventariar y clasificar datos, definir requisitos de manejo, minimizar exposición, proteger almacenamiento/transmisión y gobernar retención/eliminación. Evidencia: inventario de datos, clasificaciones, registros de DLP/cifrado y evidencia de eliminación.

7. Gobierno de configuración segura

Definir configuraciones seguras aprobadas para activos y software, propiedad de configuración, despliegue, monitoreo de desviaciones, excepciones y remediación. Distinguir CIS Benchmarks de requisitos/conceptos de CIS Controls.

8. Gestión de cuentas

Gobernar creación, modificación, deshabilitación, eliminación, propiedad, cuentas de servicio, cuentas inactivas e inventarios. Evidencia: registros IAM, revisiones y muestras de baja.

9. Gestión de control de acceso

Aplicar mínimo privilegio, acceso basado en roles/atributos, MFA cuando corresponda, revisión periódica, controles de acceso remoto y segregación de funciones. Evidencia: matriz de acceso, aprobaciones y resultados de revisión.

10. Gestión de vulnerabilidades

Definir descubrimiento, priorización, remediación, excepciones, validación y métricas. Evidencia: cobertura de escáneres, hallazgos, tickets, re-pruebas y aceptaciones de riesgo.

11. Gestión de registros de auditoría

Definir fuentes de logs, recolección, sincronización horaria, retención, protección de acceso, revisión y alertamiento. Evidencia: estándar de logging, cobertura SIEM, configuraciones de retención y registros de revisión.

12. Protecciones de correo electrónico y navegador web

Aplicar configuración segura, filtrado, controles de contenido malicioso, gobierno de extensiones, protecciones de dominio y salvaguardas de usuario. Evidencia: configuraciones, registros de gateway, listas de extensiones permitidas y pruebas.

13. Defensas contra malware

Desplegar y monitorear protecciones antimalware/endpoint, controles de comportamiento, estado de actualización, reglas de medios removibles y procesos de respuesta. Evidencia: paneles de cobertura, alertas y registros de aislamiento/remediación.

14. Controles de recuperación de datos

Mantener respaldos protegidos, puntos de recuperación, protecciones offline/inmutables cuando corresponda, pruebas de restauración, controles de acceso y objetivos de recuperación. Evidencia: reportes de respaldo y resultados de pruebas de restauración.

15. Gestión de infraestructura de red

Inventariar y administrar de forma segura dispositivos de red, configuraciones, interfaces administrativas, ciclo de vida, segmentación y control de cambios. Evidencia: inventario de red, configuraciones, cambios y resultados de revisión.

16. Monitoreo y defensa de red

Desplegar monitoreo, detección, filtrado, segmentación, análisis de tráfico y capacidades de respuesta proporcionales al riesgo. Evidencia: cobertura de sensores, alertas, reglas de firewall/red e investigaciones.

17. Concientización y capacitación en habilidades de seguridad

Proporcionar educación básica y por rol sobre amenazas actuales, reporte, manejo de datos, autenticación, ingeniería, administración y roles de incidentes. Evidencia: contenidos, finalización, ejercicios y métricas de efectividad.

18. Gestión de proveedores de servicios

Inventariar proveedores, evaluar riesgo, definir expectativas contractuales/de seguridad, monitorear desempeño, rastrear incidentes y gobernar terminación. Evidencia: registro de proveedores, evaluaciones, acuerdos y monitoreo.

19. Seguridad del software de aplicaciones

Integrar requisitos seguros, modelado de amenazas, revisión de código, gestión de dependencias, secretos, pruebas, gates de release y remediación en el SDLC. Evidencia: salidas de pipeline, hallazgos y aprobaciones.

20. Gestión de respuesta a incidentes

Mantener roles, comunicaciones, detección, triage, contención, erradicación, recuperación, preservación de evidencia, ejercicios y lecciones aprendidas. Evidencia: plan IR, incidentes, tabletop y mejoras.

21. Gobierno de pruebas de penetración

Definir alcance, competencia/independencia, reglas de compromiso, frecuencia, hallazgos, remediación y re-pruebas. Evidencia: planes, reportes y remediación. Las pruebas de penetración no reemplazan la verificación más amplia de controles.

22. Adaptación a nube y responsabilidad compartida

Mapear salvaguardas entre responsabilidades de proveedor y cliente en IaaS/PaaS/SaaS. Evidencia: matrices de responsabilidad, configuraciones cloud, aseguramiento de proveedores y seguimiento de brechas.

23. Adaptación a endpoint, móvil, IoT y trabajo remoto

Definir inventario, configuración, autenticación, cifrado, actualización, red, monitoreo y controles ante pérdida/compromiso para activos distribuidos. Evidencia: cobertura MDM/EDR, registros de dispositivos y excepciones.

24. Arquitectura de salvaguarda a evidencia

Para cada concepto de salvaguarda implementado registrar propietario, procedimiento, disparador/frecuencia, objeto y ubicación de evidencia, método de prueba, hallazgos, remediación y disparador de reevaluación. La evidencia debe permitir reconstruir la operación.

25. Propiedad de controles, RACI y cadencia

Asignar roles responsables y accountable, rutas de escalamiento, frecuencia de revisión, suplentes e interfaces interfuncionales. Verificar que la propiedad opere en la práctica y no solo en documentos.

26. Excepciones y salvaguardas compensatorias

Usar excepciones controladas con justificación, riesgo, salvaguardas compensatorias, aprobador, vencimiento, objetivo de remediación y revisión periódica. Evidencia: registro de excepciones y cierres.

27. Medición, métricas y madurez

Definir indicadores de cobertura, oportunidad, efectividad, excepciones, recurrencia y riesgo. Usar métricas para decisiones sin reemplazar el juicio cualitativo de riesgo. Evidencia: dashboards, tendencias y acciones de gestión.

28. Progresión entre Implementation Groups

Planificar el movimiento entre posturas IG según riesgo, capacidad, dependencias y recursos. Registrar brechas de prerequisites y secuencia. Evidencia: roadmap, hitos y decisiones de reevaluación.

29. Gobierno de mapeos con NIST CSF 2.0 y otros marcos

Usar crosswalks como ayuda de mapeo, no como afirmaciones de equivalencia. Mantener identidad de fuente/versión y justificación del mapeo. Evidencia: crosswalk controlado, revisor/fecha y ambigüedades no resueltas.

30. Cambio de fuentes y migración de versión

Monitorear versiones oficiales de CIS, change logs, términos de licencia, mapeos y guía de Implementation Groups. Registrar impacto y decisiones de migración; cambios materiales reabren gates afectados.

31. Preparación para evaluación y auditoría

Definir alcance de evaluación, muestreo de evidencia, pruebas de control, papeles de trabajo, hallazgos, remediación y límites de verificación independiente. La automatización puede recolectar evidencia pero no reemplaza juicio humano cuando el contexto de evaluación lo exige de forma específica.

32. Localización, QA renderizado, procedencia y controles de release

Congelar el inglés exacto antes de localizar es-419 y pt-BR. Preservar terminología CIS y marcar traducciones del proyecto como no oficiales. Exigir paridad trilingüe, revisión humana

sustantiva solo cuando esté específicamente requerida por una cuestión no determinista documentada, QA renderizado/de páginas/accesibilidad, generación reproducible de seis DOCX/PDF, SHA-256 exactos, seguridad de workflows, staging durable, publicación del predecesor y reconciliación de catálogo/registro.

Límite de release controlado

Este master localizado no establece certificación, respaldo, cumplimiento legal, aseguramiento de auditoría ni elegibilidad automática de publicación. El release permanece secuencial y fail-closed bajo los controles del repositorio; cuando no existen errores o asuntos materiales pendientes y todos los gates objetivos aplicables están verdes, aplica la autorización permanente de publicación.